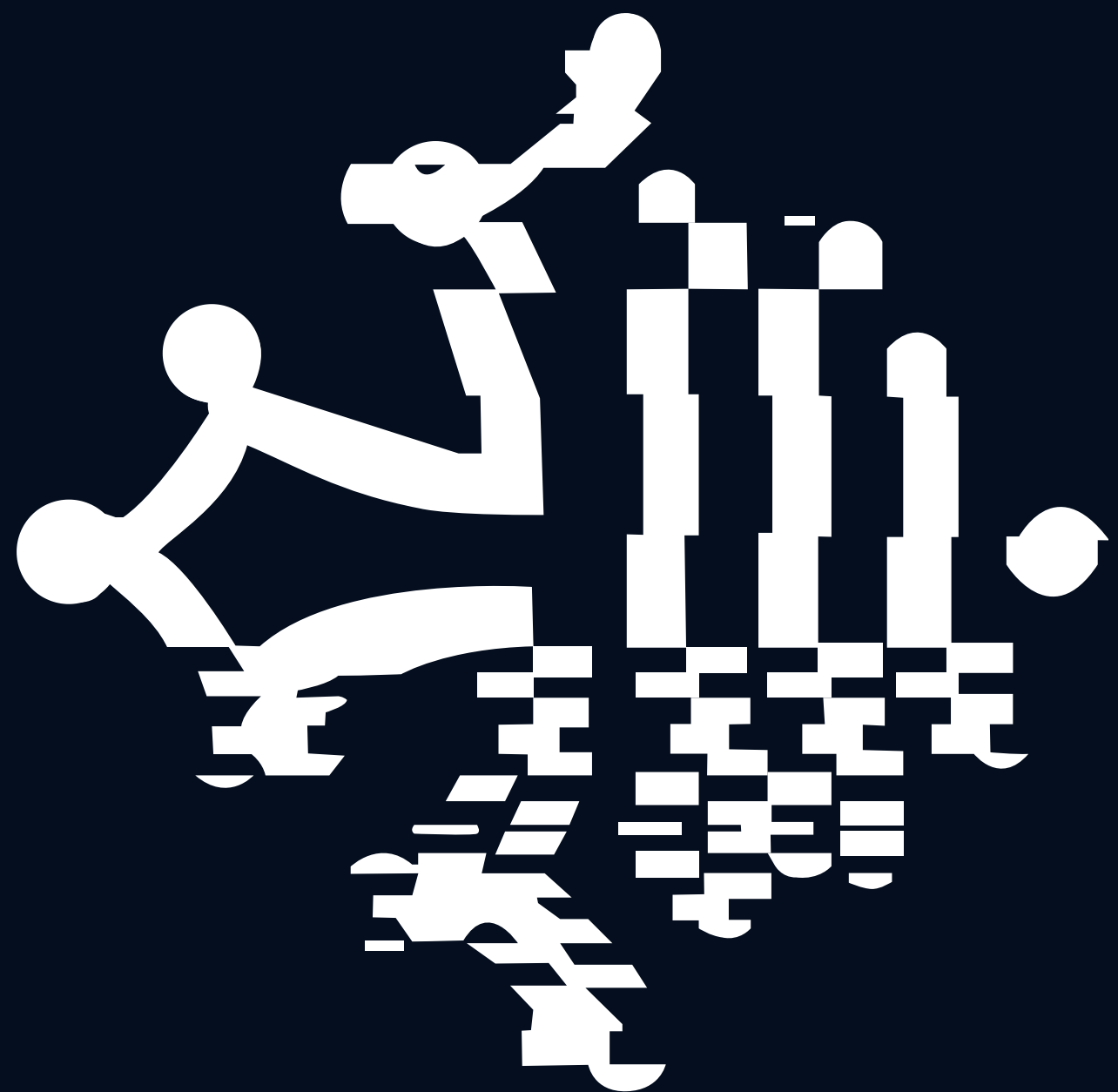


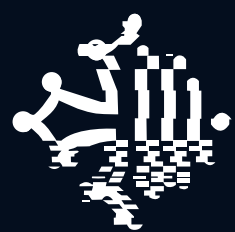


OS CYBSECURITY

CYBSEC

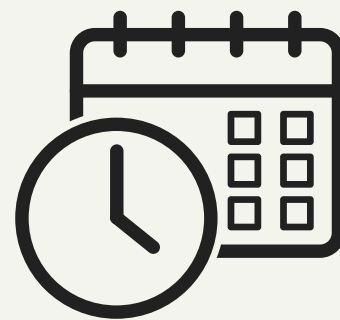
25 - 26

OXYHACK



OXYHACK

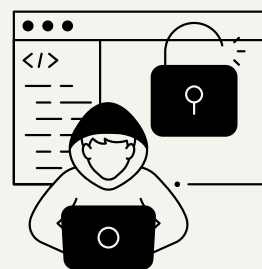
About Us :



Founded in 2023



Cybersecurity



Audit & Pentest



Cybersecurity trainers



Professional Trainings

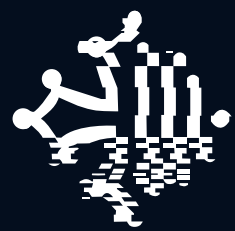


CyberEvent



On demand / Hosted
CTF Platform

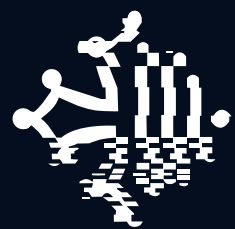
Learn It. Build it. Break it.



OXYHACK

Objective

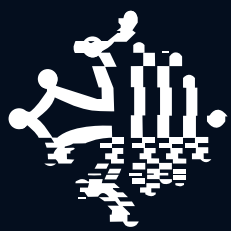
- Understand how to implement a security strategy in a Windows environment
- Understand how to implement a security strategy in a Linux environment
- Learn about cross-cutting measures to enhance system security
- Explore security solutions



OXYHACK

Content

- **Part 0 : Introduction**
- **Part 1 : Definitions and General Principles**
- **Part 2 : OS Hardening**
- **Part 3 : SIEM**



OXYHACK

Evaluation Methodology

Your performance in the course will be assessed through a comprehensive methodology designed to evaluate both theoretical understanding and practical application of cybersecurity skills.

20%

Participation & Soft Skills

Engagement in discussions, teamwork, and problem-solving approaches.

40%

Lab Work

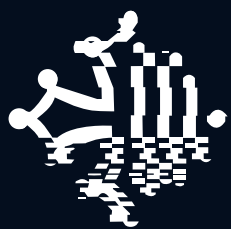
Practical exercises, hands-on challenges, and technical task completion.

40%

Final Project & Presentation

Application of learned skills in a capstone project and its defense.

Introduction



OXYHACK

Learn How to Learn

Discord Communities

Join active cybersecurity Discord servers to engage with peers, ask questions, share knowledge, and stay updated on the latest trends and vulnerabilities.

Bug Bounties

Participate in bug bounty programs to legally identify and report vulnerabilities in real-world systems, earning rewards and gaining valuable experience.

Set Up Home Labs

Build and experiment with your own home lab environment to practice skills, test security tools, and understand system vulnerabilities in a safe, controlled setting.

Continuous Learning

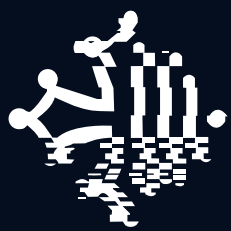
The cybersecurity landscape constantly evolves. Embrace a mindset of lifelong learning through certifications, online courses, and staying informed about new threats.

Open-Source Projects

Contribute to open-source cybersecurity projects. This provides practical coding experience, builds your portfolio, and connects you with global collaborators.

CTF Events

Participating in Capture The Flag (CTF) events demonstrates real-world problem-solving and teamwork, fostering collaboration and communication skills.



Note-Keeping Tricks

Organized Notes

Structure notes by topic or project (e.g., Pentesting Labs, CTFs, Bug Bounties) using clear titles and dates for easy retrieval.

Sync & Backup

Utilize cloud sync services to prevent data loss. Always maintain an offline copy for sensitive lab notes.

Clean Formatting

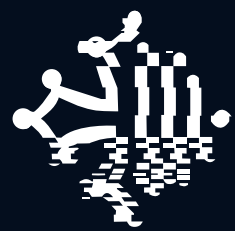
Use Markdown or simple formatting to keep notes clean, readable, and exportable, especially with tools like GitHub, Obsidian, or Joplin.

Attach Screenshots

Supplement your written notes with screenshots. Capture proof of execution and keep images alongside relevant text for comprehensive documentation.

Commands & Outputs

Always record the exact commands you ran and their outputs. This is vital for replicating your work and explaining your methodology later.



Screenshot Tools

Effective note-taking often relies on capturing visual information. These essential tools help you quickly grab screenshots on both Windows and Kali Linux environments.

Windows

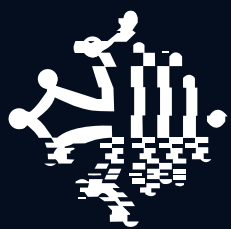
- Snipping Tool / Snip & Sketch
- Greenshot
- ShareX
- Flameshot

Linux

- Flameshot
- Shutter
- GNOME Screenshot
- scrot

Part 1:

0 . Refresh



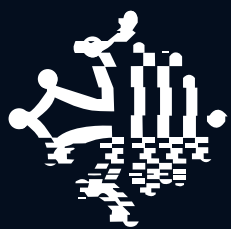
1 – Networking Refresh

Types of Networks

- **LAN (Local Area Network):** Connects devices in a limited geographical area, like a home, office, or school.
- **WAN (Wide Area Network):** Connects devices over a large geographical area, such as cities, countries, or even continents (e.g., the Internet).
- **WLAN (Wireless Local Area Network):** A LAN that uses wireless communication technology (Wi-Fi) to connect devices.
- **MAN (Metropolitan Area Network):** Spans a larger area than a LAN but smaller than a WAN, typically covering a city or a large campus.

Key Network Devices

- **Switches (Layer 2):** Connect devices within a LAN, forwarding data frames to specific destinations based on MAC addresses.
- **Routers (Layer 3):** Connect different networks (LANs, WANs) and forward data packets between them based on IP addresses, determining the best path.
- **Firewalls:** Security devices that monitor and filter incoming and outgoing network traffic based on predefined security rules.
- **Access Points:** Create a wireless local area network (WLAN), allowing devices to connect to a wired network wirelessly.



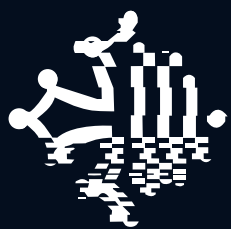
1 – Networking Refresh

OSI Model (7 Layers)

1. **Physical** : Raw bit stream over the physical medium.
2. **Data Link** : Defines format of data on the network.
3. **Network** : Determines how data is routed from source to destination.
4. **Transport** : Provides reliable data transfer services to the upper layers.
5. **Session** : Manages communication sessions between applications.
6. **Presentation** : Translates, encrypts, and compresses data.
7. **Application** : Provides network services to end-user applications.

TCP/IP Model (4 Layers)

- **Link (Network Access)** : Combines OSI's Physical and Data Link layers, handles hardware addressing.
- **Internet** : Responsible for logical addressing and routing (IP).
- **Transport** : Manages end-to-end communication and data flow (TCP, UDP).
- **Application** : Combines OSI's Session, Presentation, and Application layers, provides network services to applications.



1 – Networking Refresh

IP Addresses: The Network's Foundation

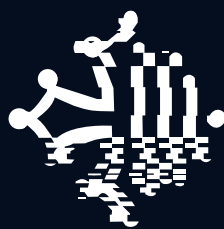
- **IPv4**: The dominant standard, using 32-bit numerical addresses.

Due to the limited address space, it's increasingly supplemented by IPv6.

- **IPv6**: The next-generation protocol, featuring 128-bit addresses, offering an enormous pool of unique identifiers to support future growth and device proliferation.

Subnetting & Network Services

- **Subnetting**: The practice of dividing a larger network into smaller, more manageable sub-networks (e.g., /24, /16).
- **NAT (Network Address Translation)**: Allows multiple devices on a private network to share a single public IP address.
- **DHCP (Dynamic Host Configuration Protocol)**: Automatically assigns IP addresses and other network configuration parameters to devices on a network.



1 – Networking Refresh

Transport Layer Essentials

TCP (Transmission Control Protocol): Provides reliable, ordered, and error-checked delivery of a stream of bytes between applications. It's "reliable" but has more overhead.

UDP (User Datagram Protocol): A simpler, faster protocol that sends independent packets without guaranteed delivery, order, or error-checking. It's "fast" and connectionless.

Common Ports to Know

SSH (Secure Shell) : Encrypted remote command-line access (Port 22)

Telnet : Unencrypted remote command-line access (Port 23)

SMTP (Simple Mail Transfer Protocol) : Sending emails (Port 25)

DNS (Domain Name System) : Resolves domain names to IP addresses (Port 53)

HTTP (Hypertext Transfer Protocol) : Web traffic (Port 80)

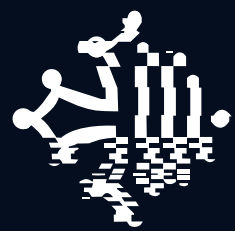
HTTPS : Secure HTTP with SSL/TLS encryption (Port 443)

RDP (Remote Desktop Protocol) : Graphical remote access (Port 3389)

Network Layer Protocols

ARP (Address Resolution Protocol): Maps an IP address to a physical MAC (Media Access Control) address on a local network. Essential for devices to find each other on the same segment.

ICMP (Internet Control Message Protocol): Used by network devices to send error messages and operational information. Key for diagnostic utilities like ping (testing reachability) and traceroute (mapping network paths).



2 – Linux Refresher

Kernel

The core of the operating system, the Kernel directly controls the CPU, memory, and hardware devices. It acts as the bridge between hardware and software, managing system resources and executing processes.

Shell

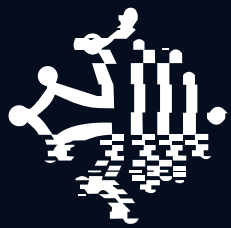
A command-line interpreter (like Bash, Zsh, or Fish) provides a user interface for accessing the operating system's services. It allows users to execute commands, scripts, and automate tasks.

File System

In Linux, everything is treated as a file, from regular documents to hardware devices. The hierarchical file system organizes data, with the root directory (/) at the top, and common directories like /home, /etc, /bin, and /var.

Processes

An instance of a running program, identified by a unique Process ID (PID). Processes are managed by the kernel, and users can interact with them using tools like `ps` (list processes), `kill` (terminate processes), and `top` (monitor processes).



2 – Linux Refresher

Navigation

- **pwd** : Print Working Directory

Displays your current location in the file system.

- **ls -la** : List Directory Contents

Shows all files and directories, including hidden ones, along with detailed permissions.

- **cd** : Change Directory

Allows you to navigate between different folders.

File Management

- **cp** : Copy files or directories.
- **mv** : Move or rename files or directories.
- **rm** : Remove files or directories.
- **nano** : A simple, user-friendly text editor for the command line.

Processes

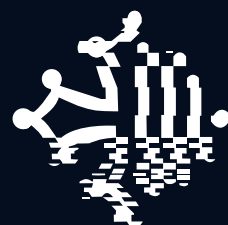
- **ps aux | grep name** : Find processes by their name.
- **kill -9 PID** : Forcefully terminate a process using its Process ID (PID).
- **htop** : An interactive process viewer that offers an enhanced experience compared to 'top'.

Permissions

- **chmod 755 file** : This command modifies file permissions, granting read, write, and execute access for the owner, and read and execute access for both the group and others.
- **chown user:group file** : This command changes the ownership of the file to a specified user and group.

Networking

- **ifconfig / ipa** : Display network interface configurations (for older and newer commands).
- **ping** : Test network connectivity to a specific host.
- **netstat -tulnp** : Show active network connections, routing tables, and interface statistics.



3 – Programming Refresher

Why ?

- Automate Repetitive Tasks
- Build Custom Tools
- Enhance Problem-Solving Skills

What ?

- Scripting Languages (Bash / Python...)
- Compiled Languages (C / C++...)
- Web Basics (Javascript..)
- APIs (Requests Library...)
- Databases

How ?

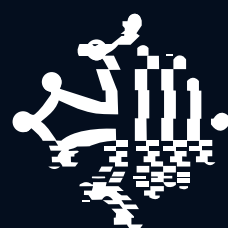
- Editors & IDEs (VS Codium, PyCharm, Vim, JetBrains...)
- Version Control (Gitea, Gitlab, Github...)
- Always write clean, readable, and well-commented code

Where ?

- Scripting and Automation => Python & Bash
- Web Exploitation => Javascript & APIs
- Low-Level Hacking => C/C++ & Assembly

Part 1:

**1. Definitions and
General Principles**



1. Definitions and General Principles

Vulnerability : Weakness at an asset level (in the design, construction, installation, configuration or use of the asset).

Threat : Potential cause of an incident, which could lead to damage to an asset if this threat materializes.

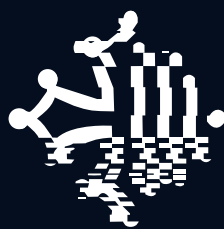
Risk : Harm x Likelihood of a Threat Occurring

Attack : Malicious action intended to compromise the security of an asset.

Safety : Sécurité

Security : Sûreté

The two terms are constantly confused because they are false friends !



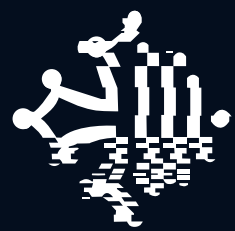
1. Definitions and General Principles

Sûreté (Safety): It refers to the protection of systems and data from non-malicious risks, such as accidents, natural disasters, hardware failures, or user errors :

- Exemple : Access point saturation, disk failure, execution error....
- Statistically quantifiable (the average lifespan of a disk is X thousands of hours)
- Countermeasures : backup, sizing, equipment redundancy....

Security: It's the protection of systems, networks, and data from malicious threats, such as unauthorized access, cyberattacks, data breaches, and sabotage :

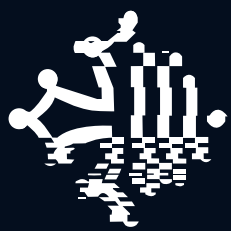
- Exemple : DDoS, modification of information, information theft...
- Not statistically quantifiable (but it is possible to assess the level of risk and the impacts upstream)
- Countermeasures : access control, security monitoring, patch management, configuration hardening...



1. Definitions and General Principles

Computer Security :

- CIA
- SPOF
- Security by Design
- Defense in depth
- Zero trust



1. Definitions and General Principles

CIA :

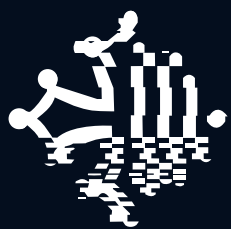
- Confidentiality : Property of goods to be accessible only to authorized persons
- Integrity : Property of accuracy and completeness of goods and information
- Availability : Property of accessibility at the desired time of the goods by the authorized persons

SPOF :

- Single Point Of Failure
- A component or subsystem whose failure would cause the entire system to stop operating. Workaround = Redundancy

Security by Design :

- Patching is very expensive and not efficient
- An approach where security is embedded into every stage of the development lifecycle, from conception and design to implementation and deployment, rather than being an afterthought.

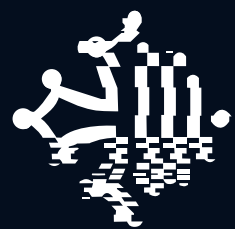


1. Definitions and General Principles

- **Defense in depth :**

To consider that the enemy can cross a line of defense without it becoming impossible to stop them, and without compromising overall security.

- Define a security perimeter (Threat is everywhere and can appear anywhere).
- Attempt to prevent intrusions into the system while preparing to limit the consequences of a successful attack.
- Set up different layers of defensive and detection devices.
- Accept the likelihood of a security incident to be better prepared.
- Slow down the attacker in order to
 - "trace" them & stop them before they do any damage
 - contain (confine) the attack/attacker & thwart the attack/adapt one's defense strategy
 - deter the attacker



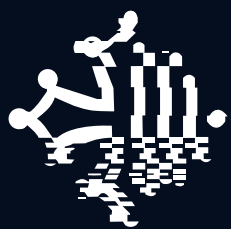
1. Definitions and General Principles

- **Zero Trust :**

Process invented by Google around 2009 as part of the "BeyondCorp" project.

Redefinition of the notion of trust and perimeter within the system :

- The notion of a "trusted network" disappears.
- All traffic is encrypted by default. (Internal too)
- Strong authentication of both the terminal and the user.
- Access control as close as possible to the resource, rather than in a distant intermediate device.
- Concept of "micro-segmentation".



OXYHACK

1. Definitions and General Principles

There are only two categories of companies :

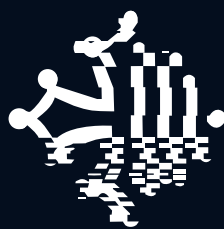
Those that have been pwned

And those who don't know it yet



Part 1:

2 . IT Hygiene & Security



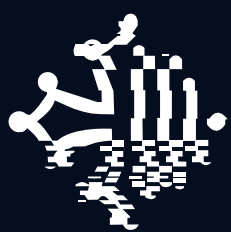
2. IT Hygiene & Security

Password Management :

- **Create Strong Passwords:** Make complex and memorable passwords using methods like phonetic phrases (e.g., "I bought 5 CDs for one hundred dollars this afternoon" becomes "1b5CDs4100\$Tam") or first-letter acronyms.
- **Use a Password Manager:** Store and create strong passwords securely with tools like KeepassXC, Bitwarden, or 1Password.
- **Change Default Credentials:** Always change factory default passwords on all new devices and services right away.

Update Your Software Regularly :

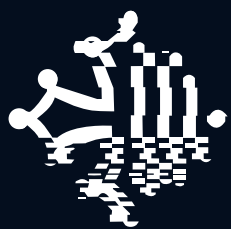
- **Enable Auto-Updates :** Set software to update automatically when possible to get security fixes quickly.
- **Monitor for Updates :** Keep an eye on security news and vendor alerts for important updates and weaknesses.
- **Use Reliable Sources :** Only download updates from official, trusted sources.



OXYHACK

2. IT Hygiene & Security

NTLM	31.82 TH/s	Instant	Instant	Instant	Instant	Instant	7 mins 6 secs	7 hrs 19 mins	2 wks 4 days
MD5	17.77 TH/s	Instant	Instant	Instant	Instant	Instant	12 mins 42 secs	13 hrs 7 mins	1 mo 0 wk
NetNTLMv1 / NetNTLMv1+ESS	16.82 TH/s	Instant	Instant	Instant	Instant	Instant	13 mins 25 secs	13 hrs 51 mins	1 mo 0 wk
LM	15.81 TH/s	Instant	Instant	Instant	Instant				
SHA1	5.89 TH/s	Instant	Instant	Instant	Instant	Instant	38 mins 18 secs	1 day 15 hrs	3 mos 1 wk
SHA2-256	2.42 TH/s	Instant	Instant	Instant	Instant	1 min 31 secs	1 hr 33 mins	4 days 0 hr	8 mos 0 wk
NetNTLMv2	1.22 TH/s	Instant	Instant	Instant	Instant	3 mins 0 sec	3 hrs 5 mins	1 wk 0 day	1 yr 4 mos
SHA2-512	801.9 GH/s	Instant	Instant	Instant	Instant	4 mins 33 secs	4 hrs 41 mins	1 wk 5 days	2 yrs 0 mo
decrypt, DES (Unix), Traditional DES	647.59 GH/s	Instant	Instant	Instant	Instant	5 mins 38 secs	5 hrs 48 mins	2 wks 1 day	2 yrs 6 mos
Kerberos 5, etype 23, TGS-REP	206.97 GH/s	Instant	Instant	Instant	Instant	17 mins 35 secs	18 hrs 10 mins	1 mo 2 wks	7 yrs 11 mos
Kerberos 5, etype 23, AS-REQ Pre-Auth	206.78 GH/s	Instant	Instant	Instant	Instant	17 mins 36 secs	18 hrs 11 mins	1 mo 2 wks	7 yrs 11 mos
md5crypt, MD5 (Unix), Cisco-IOS \$1\$ (MD5)	7.61 GH/s	Instant	Instant	Instant	7 mins 44 secs	7 hrs 58 mins	2 wks 6 days	3 yrs 5 mos	216 yrs 9 mos
LastPass + LastPass sniffed	1.78 GH/s	Instant	Instant	Instant	32 mins 54 secs	1 day 9 hrs	2 mos 3 wks	14 yrs 10 mos	924 yrs 0 mo
macOS v10.8+ (PBKDF2-SHA512)	335.09 MH/s	Instant	Instant	2 mins 50 secs	2 hrs 55 mins	1 wk 0 day	1 yr 3 mos	79 yrs 4 mos	4.9 mil
WPA-EAPOL-PBKDF2	277.23 MH/s					1 wk 2 days	1 yr 6 mos	95 yrs 11 mos	6 mil
TrueCrypt RIPEMD160 + XTS 512 bit	211.78 MH/s	Instant	Instant	4 mins 29 secs	4 hrs 37 mins	1 wk 4 days	2 yrs 0 mo	125 yrs 7 mos	7.8 mil
7-Zip	181.51 MH/s	Instant	Instant	5 mins 13 secs	5 hrs 23 mins	1 wk 6 days	2 yrs 4 mos	146 yrs 6 mos	9.1 mil
sha512crypt \$6\$, SHA512 (Unix)	119.46 MH/s	Instant	Instant	7 mins 56 secs	8 hrs 11 mins	3 wks 0 day	3 yrs 7 mos	222 yrs 7 mos	13.8 mil
DPAPI masterkey file v1	47.23 MH/s	Instant	Instant	20 mins 3 secs	20 hrs 42 mins	1 mo 3 wks	9 yrs 0 mo	563 yrs 1 mo	34.9 mil
RAR5	28.15 MH/s	Instant	Instant	33 mins 39 secs	1 day 10 hrs	2 mos 4 wks	15 yrs 2 mos	944 yrs 11 mos	58.6 mil
DPAPI masterkey file v2	27.82 MH/s	Instant	Instant	34 mins 2 secs	1 day 11 hrs	2 mos 4 wks	15 yrs 5 mos	955 yrs 11 mos	59.3 mil
RAR3-hp	20.84 MH/s	Instant	Instant	45 mins 26 secs	1 day 22 hrs	3 mos 4 wks	20 yrs 6 mos	1.3 mil	79.2 mil
KeePass 1 (AES/TwoFish) and KeePass 2 (AES)	17.8 MH/s	Instant	Instant	53 mins 12 secs	2 days 6 hrs	4 mos 2 wks	24 yrs 1 mo	1.5 mil	92.7 mil
bcrypt \$2*\$, Blowfish (Unix)	11.37 MH/s	Instant	1 min 21 secs	1 hr 23 mins	3 days 14 hrs	7 mos 1 wk	37 yrs 8 mos	2.3 mil	145.1 mil
Bitcoin/Litecoin wallet.dat	3.55 MH/s	Instant	4 mins 18 secs	4 hrs 26 mins	1 wk 4 days	1 yr 11 mos	120 yrs 8 mos	7.5 mil	464.2 mil
Speed		Length 4	Length 5	Length 6	Length 7	Length 8	Length 9	Length 10	Length 11



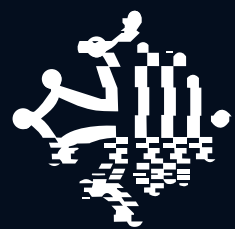
2. IT Hygiene & Security

Know your users and service providers well :

- 1.Ensure that all users accessing the system are properly identified, authenticated, and authorized
- 2.Establish a level of trust based on the user's role and responsibilities
- 3.Ensure that the third-party service providers you work with are reputable and follow strong security practices

Perform regular backups :

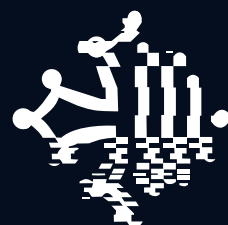
- 1.Apply the 3-2-1-1-0 rule !
- 2.Testing Backups and Restores



2. IT Hygiene & Security

Secure Your Wi-Fi Access :

1. Prefer wired access
2. Set encryption (WPA2 minimum)
3. Modify default connection keys and regularly change them
4. Never use "public wifi" without a VPN
5. In a professional setting, use a portal login for Wi-Fi access



2. IT Hygiene & Security

Be as careful with your smartphone as you are with your computer :

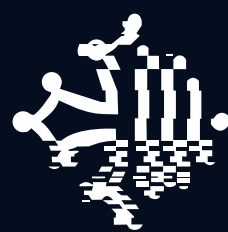
1. These devices often store or access sensitive information
2. Mobile devices are frequently used for personal and professional tasks, making them prime targets for attackers

Download software from official publisher sites

Always download software from official publisher sites or trusted app stores.

Separate personal uses from professional uses :

1. Isolate professional VS personal messaging
2. No professional data on personal equipment
3. Beware of removable media



OXYHACK

2. IT Hygiene & Security

Take care of personal and professional information and digital identity :

Have I Been Pwned?

This service allows you to check if your email address or phone number has been compromised in a data breach.

Mozilla Monitor

Similar to Have I Been Pwned, Mozilla Monitor provides ongoing alerts if your online accounts are found in new data breaches.

Find where your private info is exposed — and take it back

We scan data breaches to see if your data has been leaked and give you steps to fix it.

[Get free scan](#)

Enter your email address to check for data breach exposures.

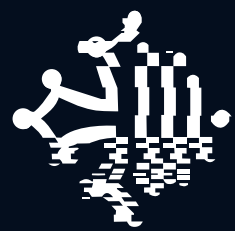
';--have i been pwned?

Check if your email address is in a data breach

[pwned?](#)

Part 1:

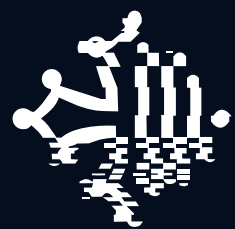
**3 . Protect and
Defend**



2. Protect & Defend

Backup

- 1.What?
- 2.Why?
- 3.When? (+ Periodicity)
- 4.Duration of storage/retention ?
- 5.Where? (+ Redundancy)
- 6.How? (tools, methods, encryption...)



2. Protect & Defend

Monitoring & Detection :

It allows for the real-time detection of threats, anomalies, and unauthorized activities, enabling quick responses to potential security incidents, and helping to prevent or minimize damage to the system.

1. Supervision :

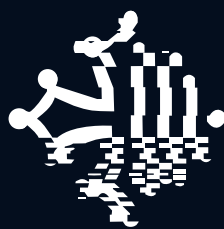
a. Protocol :SNMP, TCP, local / cloud agent

b. How : via logs

i. Centralization

ii. Syslog

c. Solutions : Centreon, Zabbix, Suricata, Wazuh, Splunk, Qradar, ELK...



2. Protect & Defend

PSSI (Security Policy) :

1. Preamble: definition of the perimeter
 - a. What to protect ?
 - b. Why ?
 - c. Against whom / what ?
 - d. How ?
2. What is allowed ?
3. What's forbidden (denied) ?

What to protect :

Sensitive data, intellectual property, critical infrastructure.

Why :

Compliance, business continuity, reputation, trust.

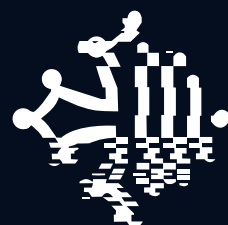
Against whom / what :

Cyber threats, insider risks, accidental data loss.

How :

Through defined controls, procedures, and technologies.

1. Sensibilisation
2. Responsabilité
3. Réaction
4. Éthique
5. Démocratie
6. Évaluation des risques
7. Conception et mise en œuvre de la sécurité
8. Gestion de la sécurité
9. Réévaluation



2. Protect & Defend

Audit :

Why ? To check the proper application / compliance of the security policy.

Organizational Audits

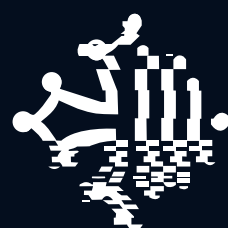
Focus on processes, policies, and compliance frameworks :

- Risk Analysis: Methodologies like EBIOS to identify and assess potential security risks.
- Personal Data Management : Ensuring compliance with regulations like GDPR through tools such as CNIL's PIA.
- Compliance Audits : Verifying adherence to industry standards and certifications (e.g., ISO 27001/27002).

Technical Audits

Examine the security posture of systems and infrastructure :

- Vulnerability Analysis: Utilizing tools to identify system vulnerabilities.
- Penetration Testing: Simulating cyberattacks to find exploitable weaknesses in systems and applications.



OXYHACK

2. Protect & Defend

In the realm of cybersecurity, two distinct teams play crucial, often adversarial, roles in fortifying an organization's defenses.

Red Team

Role: Offensive.

Objective: To emulate real-world adversaries by finding and exploiting vulnerabilities, rigorously testing the effectiveness of the organization's defenses, and providing actionable insights into potential attack vectors.

Mindset: "Think like an attacker." This involves adopting the strategies and techniques of malicious hackers to uncover weaknesses before they can be exploited.

Blue Team

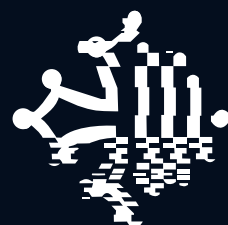
Role: Defensive.

Objective: To continuously protect the organization by identifying and closing security gaps, responding to threats in real-time, and preventing unauthorized access or damage to systems and data.

Mindset: "Defend the network." This requires constant vigilance, rapid incident response, and a deep understanding of defensive security technologies and practices.

Together, these teams form a vital feedback loop, enabling continuous improvement in cybersecurity posture through simulated attacks and robust defense strategies.





2. Protect & Defend

Blue Team

Beyond the distinct roles of Red and Blue Teams, some organizations adopt a Purple Team approach. This strategy fosters a collaborative environment where offensive and defensive insights are shared, leading to a more robust and adaptable security posture.

Enhanced Collaboration

The Purple Team facilitates direct communication and synergy between offensive (Red) and defensive (Blue) strategies. This breaks down silos, enabling both teams to learn from each other's perspectives and operations.

Shared Insights & Knowledge

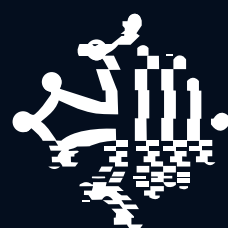
Instead of working in isolation, the Purple Team model encourages the sharing of real-time attack methodologies, discovered vulnerabilities, and defensive counter-measures. This accelerates the feedback loop for security improvements.

Continuous Improvement

By constantly refining both offensive techniques and defensive capabilities, organizations can achieve a higher level of security maturity. This proactive approach ensures defenses are continually tested and optimized against evolving threats.

Part 1:

4. NIST



4. NIST

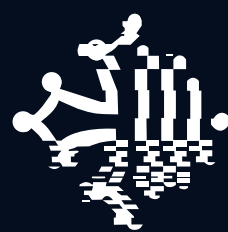
NIST ?

National Institute of Standards and Technology - *NIST Cybersecurity Framework*

It provides a comprehensive, flexible, and widely recognized set of guidelines and best practices for managing and improving cybersecurity in organizations of all sizes and industries.

5 pillars for a complete, holistic and effective cybersecurity program :





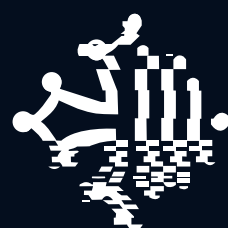
4. NIST

Identify :

The Identify function helps develop an organizational understanding of cybersecurity risk management for systems, people, assets, and data.

Key Activities:

- Identify physical and software assets to establish an Asset Management program.
- Understand the Business Environment, including the organization's role in the supply chain and critical infrastructure sector.
- Define the Governance program by identifying established cybersecurity policies and legal/regulatory requirements.
- Assess asset vulnerabilities, threats, and risk response activities to support the organization's Risk Assessment.
- Develop a Risk Management Strategy, including risk tolerances.
- Formulate a Supply Chain Risk Management strategy



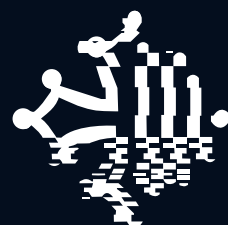
4. NIST

Protect :

The Protect function outlines safeguards to ensure the delivery of critical infrastructure services and to limit or contain the impact of potential cybersecurity events.

Key Activities:

- Implement protections for IAM and ACL, covering both physical and remote access.
- Empower staff through Awareness and Training.
- Establish Data Security measures consistent with the organization's risk management strategy.
- Implement Information Protection Processes and Procedures.
- Protect organizational resources through regular and remote maintenance activities.
- Manage Protective Technology to ensure the security and resilience of systems and assets



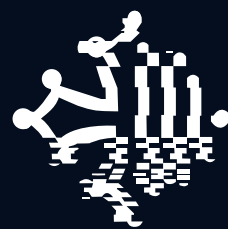
4. NIST

Detect :

The Detect function outlines activities to identify the occurrence of cybersecurity events, enabling their timely discovery.

Key Activities:

- Ensure anomalies and events are detected, with an understanding of their potential impact.
- Implement continuous security monitoring to track cybersecurity events and verify the effectiveness of protective measures, including both network and physical activities.
- Maintain detection processes to increase awareness of abnormal events.



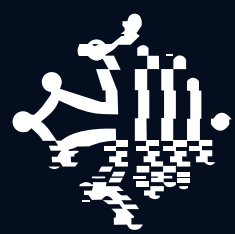
4. NIST

Respond :

The Respond function outlines activities to take action in response to a detected cybersecurity incident, aiming to contain its impact.

Key Activities:

- Ensure response planning processes are executed during and after an incident.
- Manage communications with internal and external stakeholders, including law enforcement, during and after an event.
- Conduct analysis to ensure an effective response, support recovery, and assess the impact of incidents, including forensic analysis.
- Perform mitigation activities to prevent the incident from escalating and to resolve it.
- Implement improvements by incorporating lessons learned from past detection and response activities.



4. NIST

Recover :

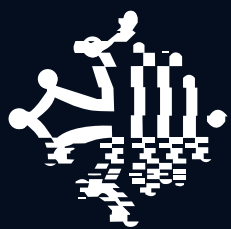
The Recover function identifies activities to maintain resilience and restore capabilities or services impaired by a cybersecurity incident. It ensures a timely recovery to normal operations, minimizing the impact of the incident.

Key Activities:

- Implement recovery planning processes and procedures to restore systems and assets affected by cybersecurity incidents.
- Apply improvements based on lessons learned and reviews of existing strategies.
- Coordinate internal and external communications during and after recovery from a cybersecurity incident.

Part 2 : OS Hardening

1. Introduction to System Hardening



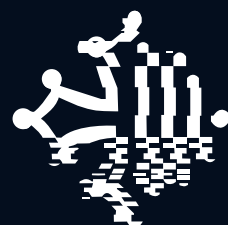
1. Introduction to System Hardening

Why harden an OS ?

Minimize the attack surface without compromising the quality of service

Process to follow :

1. **Take it Step-by-Step** : Apply hardening techniques gradually, one after another, allowing for testing and adjustments.
2. **Iterative Approach** : Harden, then test, harden, then test. This continuous cycle ensures that security measures do not inadvertently break critical services.
3. **Balance is Key** : Excessive blocking can lead to a loss of services. Finding the right balance for our needs and requirements.
4. **Document Everything** : Maintain detailed records of all updates and hardening changes in order to be able to reverse blocking changes.



1. Introduction to System Hardening

Documentation & Planning

Document everything : Maintain detailed records of all updates, configurations, and hardening changes.

Backups : Implement regular, tested backup strategies.

Storage Redundancy (RAID) : Ensure data availability and protection against disk failures.

Physical & Boot Security

Secure physical access : Protect servers and sensitive equipment from unauthorized physical access.

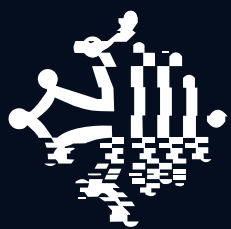
Secure Boot (BIOS/UEFI/GRUB) : Enable BIOS/UEFI passwords and secure boot options to prevent unauthorized system modification.

Encrypt storage media : Protect data at rest by encrypting hard drives and other storage devices.

Software Management

Keep systems updated : Regularly apply security patches and updates to servers and clients (e.g., WSUS, Unattended-Upgrades).

Minimal installation : Only install essential applications, roles, and features on servers and workstations. Disable or remove unnecessary services.



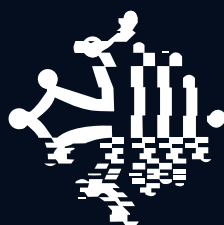
1. Introduction to System Hardening

Apply good administration practices & avoid common mistakes

- Do not turn off UAC (User Access Control)
- Using strong passwords
- Monitoring your server activity
- Set up "Account Lockout Group Policy"
- If you can, use minimal terminal servers (Wk22 Core or Minimal Server Linux)

Physical Security & User Access

- Physical security is as crucial as logical security
- Separate Privileged Accounts from Standard User Accounts
- No one should use their normal identity to administer the IS



1. Introduction to System Hardening

On-Premises

The customer has full control and responsibility for all aspects of the infrastructure, hardware, and software, hosted locally within their own facilities.

IaaS (Infrastructure as a Service)

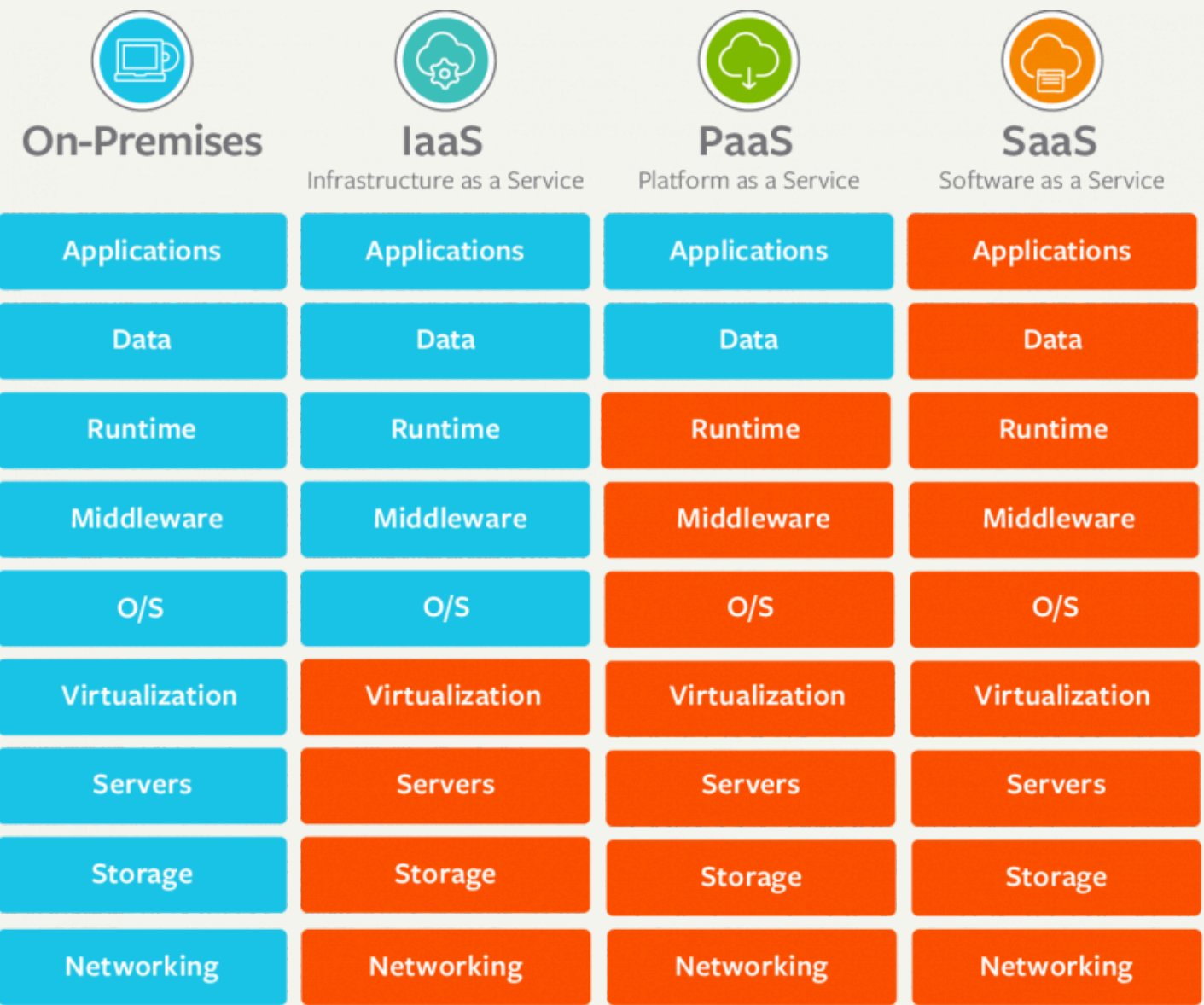
The service provider offers virtualization services, including compute, storage, and networking. The customer manages operating systems, applications, and data.

PaaS (Platform as a Service)

The customer subscribes to development and deployment platforms, not managing the underlying infrastructure, but retaining control over applications and data.

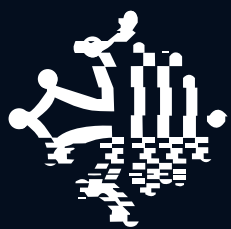
SaaS (Software as a Service)

The customer simply accesses fully managed software applications hosted by the provider, consuming them as a service without managing any infrastructure.



Part 2 : OS Hardening

2 . Windows Hardening



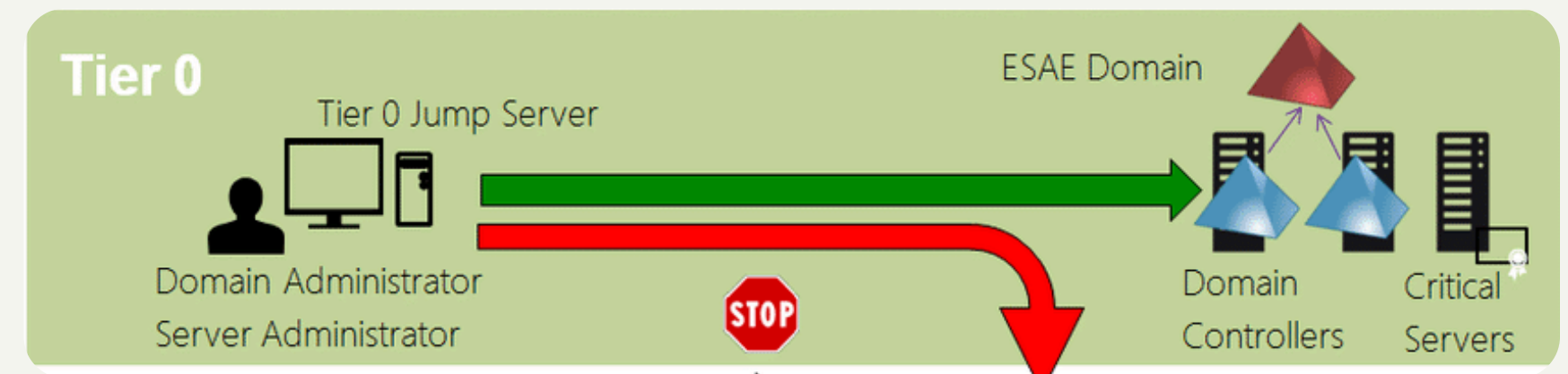
OXYHACK

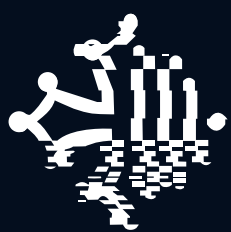
2 . Windows Hardening

Tiered Model :

- **Tier 0**

- Systems,accounts and security groups for the highest levels of security (DC, Azure AD, IAM systems...)
- Critical assets only
- Few assets, the fewer the better
- Admins = rights to all lower Tier
- Use as limited as possible
- Extensive access control and verification



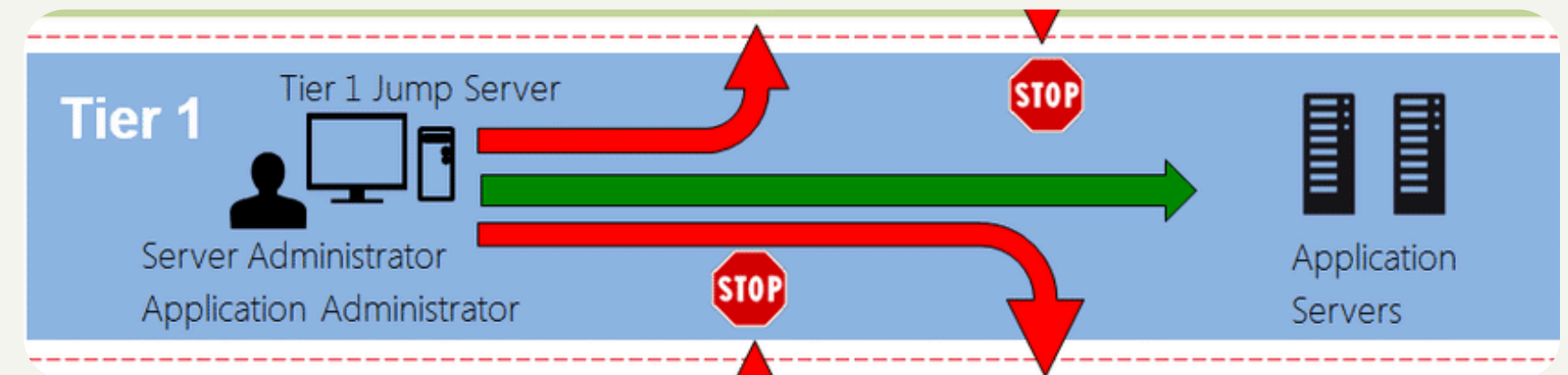


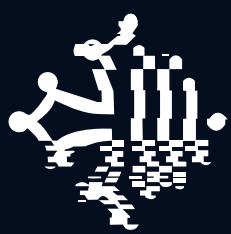
2 . Windows Hardening

Tiered Model :

- **Tier 1**

- Work servers, file servers, Web application, Servers, DB...
- Apply the same protection as tier 0
- Create a child OU (Organizational Unit) for each Business Unit, application or function
- Group policies can be used to define restricted groups whose names follow the naming scheme
- Members of a group are restricted to the systems in their group and do not have access too ther tier 1 groups
- Prohibit non-essential functionalities on these servers (email or Internet access...)



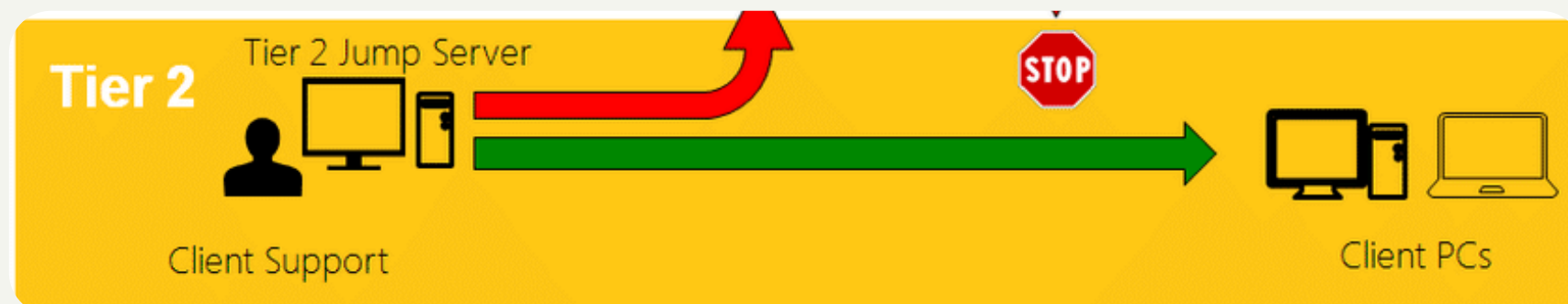


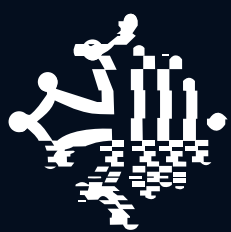
OXYHACK

2 . Windows Hardening

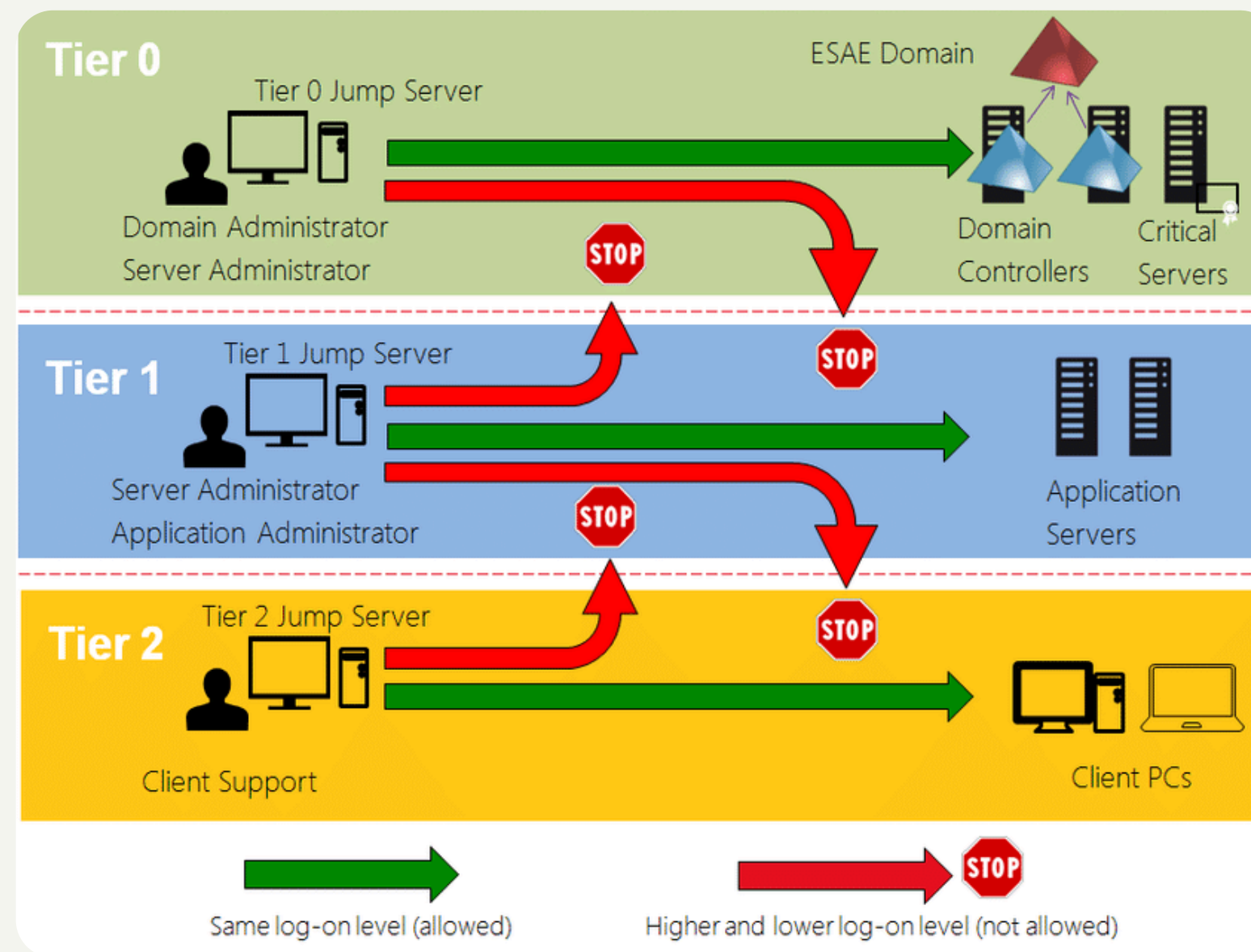
Tiered Model :

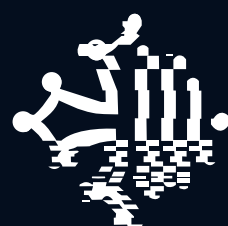
- **Tier 2**
 - Contains common devices
 - Tier used by level 1 support teams
 - Tier2 administrators should only be allowed to connect toTier 2





2 . Windows Hardening



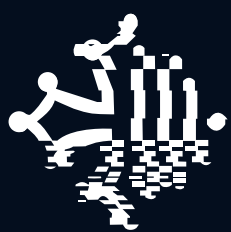


OXYHACK

2 . Windows Hardening

The screenshot displays the Group Policy Management console. On the left, the 'Tier 0 Admins' group is selected under the 'Tier 0' container. The right pane shows the 'Tier 0 Admins' group with two linked Group Policy Objects (GPOs).

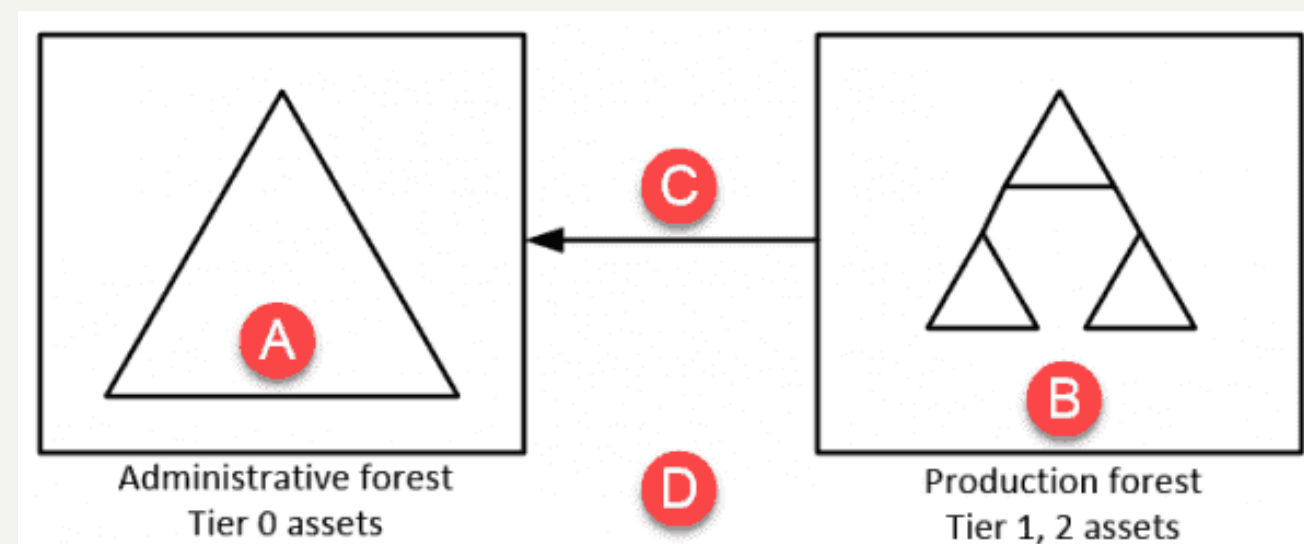
Link Order	GPO	Enforced
1	Prod SCM Tier 0 IE1...	No
2	Prod SCM Tier 0 Wi...	No

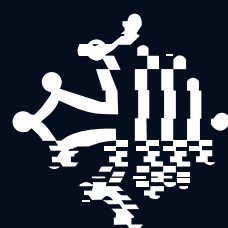


2 . Windows Hardening

ESAE : Enhanced Security Administrative Environment

- AD forest design pattern
- Build a separate AD forest which will be used exclusively for administrative tasks
- A "one-way trust" from the production forest to the administrative forest
- This approach completely isolates privileged accounts from standard user accounts

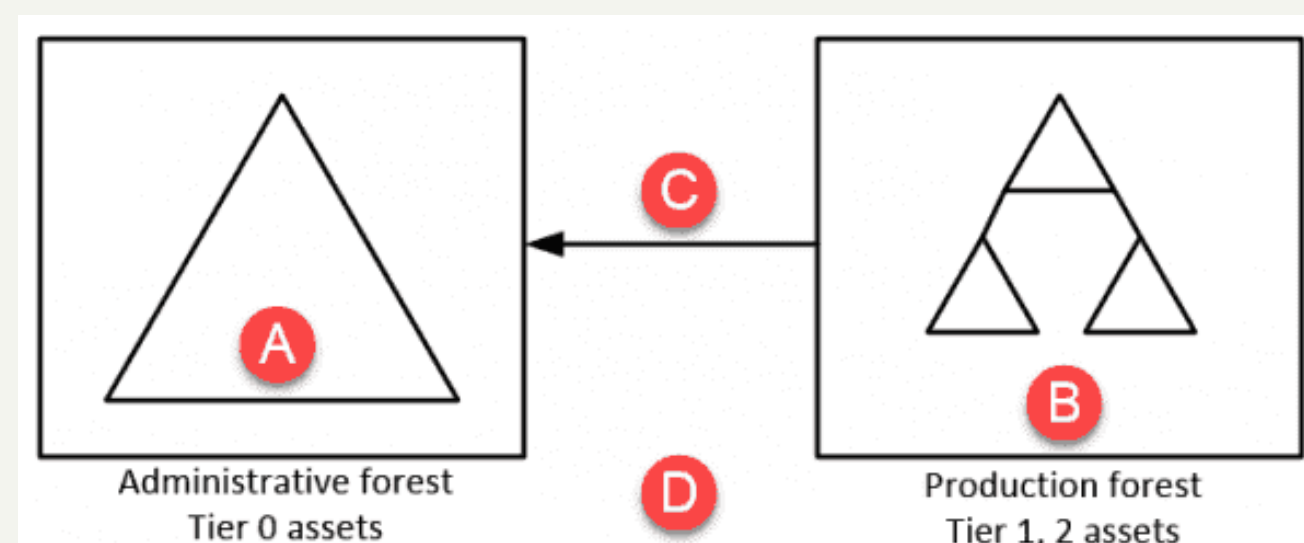


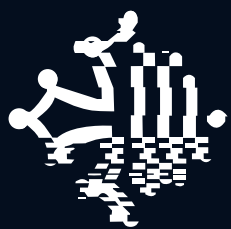


2 . Windows Hardening

ESAE : Enhanced Security Administrative Environment

- A: This is the "red" forest in which we isolate Tier 0 assets
- B: This is the production forest.
- C: We use a one-way forest trust and selective authentication to strictly control authentication flow and resource access.

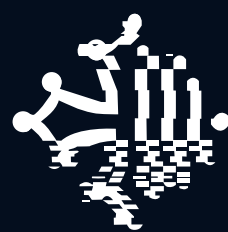




2 . Windows Hardening

Privileged Access Management

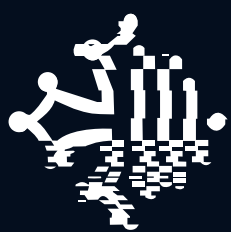
- 1.Enforce the use of multi-factor authentication (MFA)
 - a.Azure MFA or another solution
- 2.Deploy a PAM (Privileged Access Management) solution
- 3.Use "just-in-time"access to dynamically assign temporary rights and avoid permanent rights on privileged accounts
 - a.Azure PIM (Privileged Identity Management) + Azure Security Center just-in-time access
- 4.Have a procedure for provisioning/de-provisioning accounts, in particular making it possible to automatically deactivate the accounts of employees leaving the organization
- 5.Separate standard accounts from administrative accounts



2 . Windows Hardening

Privileged Access Management

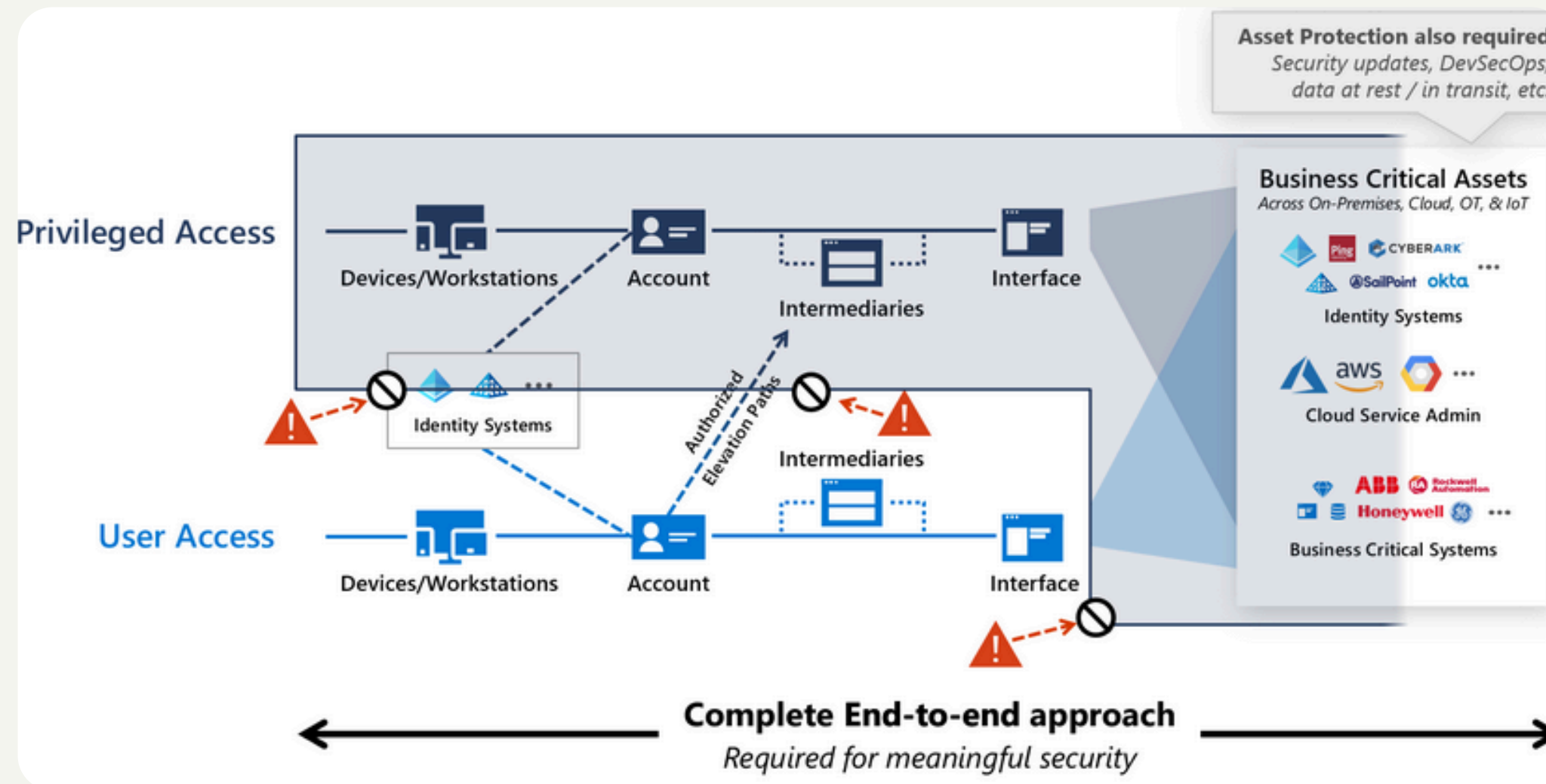
1. Limit access to email and web browsing from sensitive systems
2. Enforce a strict password policy for administrative accounts
3. Audit privileged accounts regularly
4. Drastically limit the number of administrator accounts
 - a. Follow the principle of least privilege and always be based on job / function role when provisioning administrative accounts
5. Limit the number of emergency "master key / backdoor" type accounts as much as possible and strictly monitor their use
6. Require that every change or modification in the environment goes through an approval process by an appropriate commission

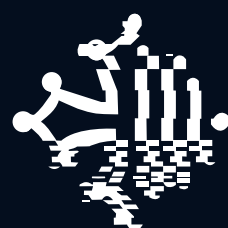


OXYHACK

2 . Windows Hardening

Privileged Access Management





2 . Windows Hardening

References

- **Microsoft Security baseline :**

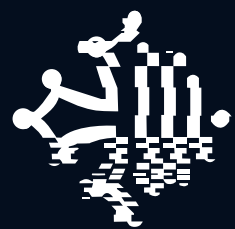
- A security baseline is a group of Microsoft-recommended configuration settings that explains their security implication. These settings are based on feedback from Microsoft security engineering teams, product groups, partners, and customers.

- **CIS Benchmarks :**

- Center for Internet Security Benchmarks, are a set of globally recognized and consensus-driven best practices to help security practitioners implement and manage their cybersecurity defenses.

- **STIGs :**

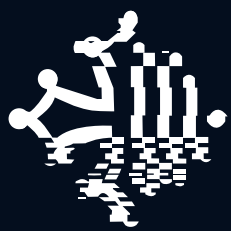
- Security Technical Implementation Guides, are published by the Defense Information Systems Agency (DISA) and provide configuration recommendations to strengthen the security of systems and applications, including Windows systems.



2 . Windows Hardening

Ressources :

- [Privileged Access Workstation](#)
- [Microsoft Security Compliance Toolkit](#)
- [Security baselines](#)
- [Configure Security Settings & Policies for Windows Server](#)
- [CIS Benchmarks](#)

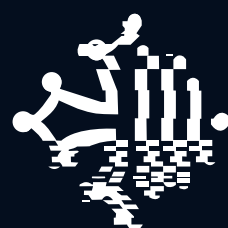


2 . Lab Windows

- Download a Windows Server 2022 ISO
 - [Windows Server 2022 ISO](#)
 - [Virtio ISO \(If needed\)](#)
- Deploy a Windows Server
- Make the server a working AD
- Choose either CIS Benchmarks or Microsoft Security baseline and harden the machine based on it
- Audit your modifications
- Present the before and after and what you have done

Part 2 : OS Hardening

3 . Linux Hardening



3 . Linux Hardening

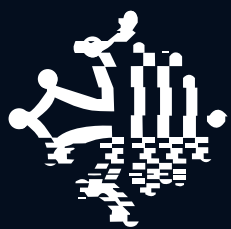
Principle of Least Privilege

Similar to the Tiered Model, the principle of least privilege is fundamental in Linux. Users and processes should only have the minimum privileges necessary to perform their functions. This is enforced through tools like sudo, user and group permissions, and discretionary access control (DAC).

Mandatory Access Control (MAC) Frameworks

MAC frameworks provide a powerful layer of security by enforcing system-wide access policies, complementing traditional discretionary access controls.

- **SELinux (Security-Enhanced Linux):** Provides a set of security policies and contexts that tightly control what processes and users can do. SELinux enforces strong access controls and is particularly used in Red Hat-based distributions.
- **AppArmor:** Another MAC system that provides profile-based security for applications. It is often used in Ubuntu and SUSE distributions.



3 . Linux Hardening

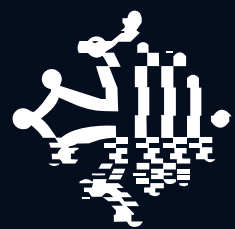
Hardening Principles, Mechanisms, and Tools

- **User and Access Management**

- RBAC (Role-Based Access Control) : While not as formalized as Windows' Tiered Model, Linux systems can implement RBAC through a combination of user groups, sudo policies, and AppArmor/SELinux policies.
- Namespace and Cgroups: Linux containers and namespaces allow for isolating processes and limiting their access to system resources (LXC, Docker...).

- **Network Segmentation and Firewall Configuration**

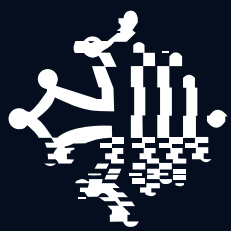
- Tools like ufw, iptables or its successor nftables are used to enforce strict network segmentation and access controls, akin to the segmentation in the Tiered Model for network traffic in Windows environments.
- Best Practices : Close all default ports (DENY ALL), Open only necessary ports (whitelisting).



3 . Linux Hardening

Hardening Principles, Mechanisms, and Tools

- **DAC (Discretionary Access Control)**
 - Users & Groups Management : id, chown, groups
 - Assign users to appropriate groups to enforce access controls.
 - Permissions & Rights: chmod, sudo
 - Set file permissions based on the principle of least privilege use sudo to allow users to perform administrative tasks without granting them full root access.



3 . Linux Hardening

Hardening Principles, Mechanisms, and Tools

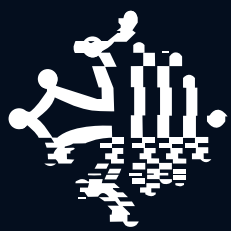
- **Security Enhanced Practices for Desktop Environments**

AppArmor Profiles : Use to confine applications like web browsers and other desktop applications to limit their access to system resources.

Disabling Unnecessary Services : Similar to server hardening, ensuring that only essential services are running on a desktop environment reduces the attack surface.

- **Centralized Logging and Monitoring**

syslog/journald for logging, with tools like Auditd and OSSEC for monitoring and alerting. These tools help in monitoring activities and enforcing compliance, similar to how centralized logging and monitoring are used in the ESAE model.



3 . Linux Hardening

Hardening Principles, Mechanisms, and Tools

- **Only Install Software from Trusted Sources**

- Debian Security Repository, RHEL Repo....

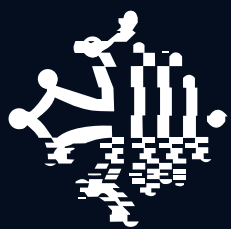
Ensure that all software packages are sourced from official and trusted repositories such as Debian Security or Red Hat Enterprise Linux (RHEL) repositories. This reduces the risk of installing compromised or malicious software.

- Best Practices :

Use apt on Debian/Ubuntu to ensure packages are signed and verified.

Use yum or dnf on RHEL/CentOS to manage packages from trusted sources.

Regularly audit and review repositories to ensure they remain secure.



3 . Linux Hardening

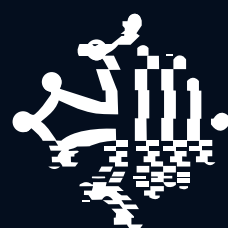
Hardening Principles, Mechanisms, and Tools

- **Keeping Your System Updated**

- Regularly applying updates is critical to ensuring that your system is protected against the latest vulnerabilities. This includes both operating system updates and updates for installed software.
- Automated Updates : Configure automatic updates for security patches using tools like `unattended-upgrades` on Debian or setting up a cron job for `yum-cron` on RHEL.

- **Limit Installed & Running Programs to What Is Strictly Necessary**

- Principle of Minimalism : Reduce the attack surface by only installing and running essential programs and services.
- Regularly audit running services and processes and disable or uninstall unnecessary services and applications.



3 . Linux Hardening

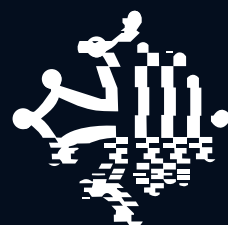
Hardening Principles, Mechanisms, and Tools

- **Secure Login with Password PAM**

- PAM (Pluggable Authentication Modules) :
 - PAM provides a dynamic way of integrating multiple low-level authentication schemes.
 - Configure PAM to enforce strong password policies, such as password complexity, expiration, and reuse.
 - Implement two-factor authentication (2FA) where possible.

- **Using Cryptographic Tools and Mechanisms**

- For Securing Communications : Stream Encryption
 - Use tools like OpenSSL or GnuTLS to encrypt network traffic.
 - Ensure that services like SSH, HTTPS, and VPNs are configured to use strong encryption algorithms.



3 . Linux Hardening

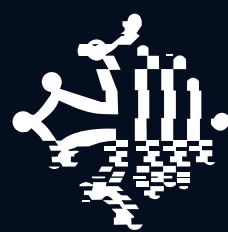
Hardening Principles, Mechanisms, and Tools

- **Using Cryptographic Tools and Mechanisms**

- For Securing Stored Data : Data Encryption
 - Implement full-disk encryption using tools like LUKS (Linux Unified Key Setup) on Linux.
 - Encrypt sensitive files and directories using gpg or similar tools.
- For Data Integrity : Hashing
 - Use hashing algorithms to verify the integrity of files and data.
 - Regularly check the integrity of critical system files.

- **Prevent Unwanted Loss or Modification of Data (Availability, Integrity)**

- Backup and Restore !



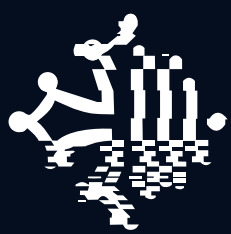
3 . Linux Hardening

Hardening Principles, Mechanisms, and Tools

- **MAC & DAC**

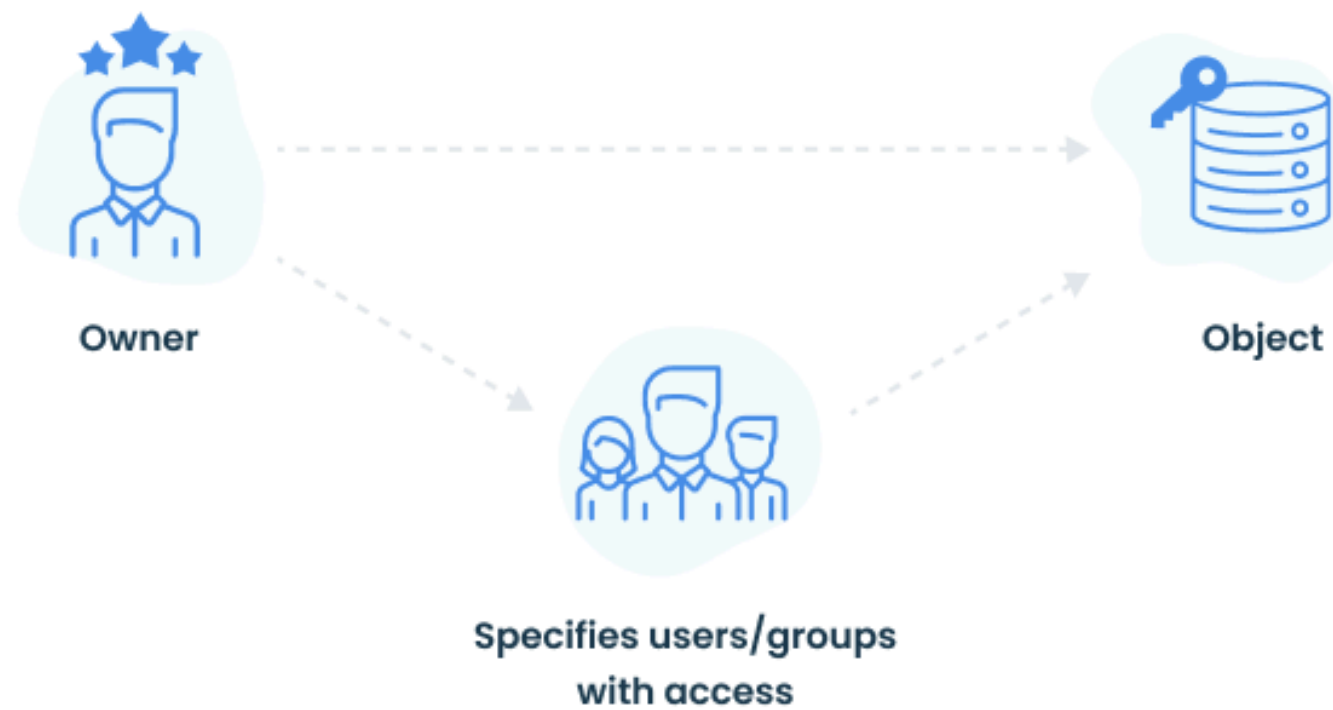
Under standard Linux Discretionary Access Control (DAC), an application or process running as an user (UID or SUID) has the user's permissions to objects such as files, sockets, and other processes.

Running a MAC kernel protects the system from malicious or flawed applications that can damage or destroy the system.



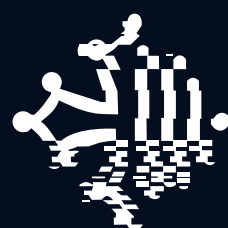
3 . Linux Hardening

Discretionary Access Control (DAC)



Mandatory Access Control (MAC)

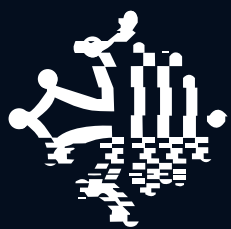




3 . Linux Hardening

References :

- Center of Internet Security (CIS): Please see CIS Benchmarks.
- Security Technical Implementation Guide (STIG): Please see Stigviewer to explore all stigs.
- National Institute of Standards and Technology (NIST): Please see National Checklist Program (NCP).
- Payment Card Industry Data Security Standard (PCI-DSS): PCI-DSS compliance is a requirement for any business that stores, processes, or transmits cardholder data.
- ANSSI Guide



3 . Linux Hardening / Fedora

Hardening a Fedora Server: SELinux, File System Control, and Exposure Management

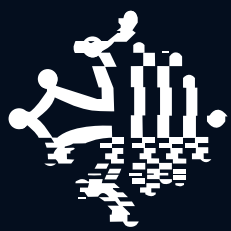
Context:

You are part of a Red Team assessment for a public-facing Fedora-based infrastructure.

Your job is to strengthen the operating system before it goes into production. The server will be exposed on a DMZ and must strictly control applications, services, and user permissions. The server will be used for SSH/FTP and Web access.

Objectives:

- Deploy and secure a minimal Fedora Server.
- Ensure data integrity and service confinement using native Fedora mechanisms.
- Harden the system based on security standards or benchmarks.



3 . Linux Hardening / Fedora

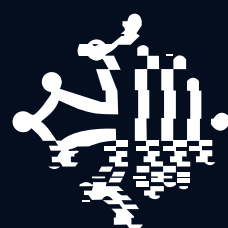
Hardening a Fedora Server: SELinux, File System Control, and Exposure Management

Constraints :

- Use a XFS file system with strict partitioning: /, /home, /var, /efi, and /tmp must be separated.
- No GUI
- A Mandatory Access Control system must be used and configured.
- Audit the system before and after hardening using Lynis.
- Present a comparison between the initial and final states of the machine.

Expected Outcomes:

- A detailed technical report (before/after hardening, justification, evidence)

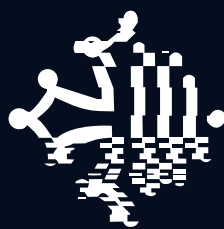


3 . Linux Hardening / Fedora

Hardening a Fedora Server: SELinux, File System Control, and Exposure Management

Commands to include in the final report

- lsblk -f
- findmnt -t xfs
- lsblk -f | grep efi
- getenforce
- sestatus
- ls -l /var/log/lynis*
- mount | grep /tmp
- ausearch -m avc
- auditctl -l
- getenforce
- systemctl status firewalld
- firewall-cmd --list-all
- ss -tuln
- grep hardening_index /var/log/lynis-report.dat
- cat /etc/fstab | grep /tmp
- systemctl list-unit-files --type=service | grep enabled
- rpm -qa --last | head -n 10



3 . Linux Hardening / Debian

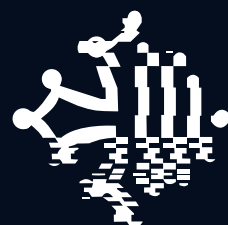
Hardening a Debian Server: Logical Volume Management, Access Control, and Audit Policies

Context:

You are assigned to harden an internal Debian server that stores and processes sensitive data. The organization requires strong disk encryption, strict user access control, and real-time monitoring of system integrity.

Objectives:

- Install and configure a minimal Debian Server.
- Design a partition layout based on LVM and full disk encryption.
 - Separate the following partitions: /, /home, /var, /tmp, /opt, /boot, /boot/efi & encrypt the entire LVM volume.
- Harden Debian based on PCI-DSS guide
- Monitor critical files for unauthorized changes (File Integrity Monitoring).
- Audit the system before and after hardening using a tool of your choice (e.g., Lynis).



3 . Linux Hardening / Debian

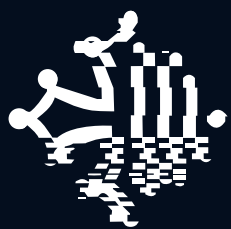
Hardening a Debian Server: Logical Volume Management, Access Control, and Audit Policies

Constraints :

- Partitioning must use LVM with logical volumes
- All partitions (except /boot/efi) must use the ext4 filesystem.
- Use LUKS encryption on the LVM group.
- No GUI should be installed.
- Implement a tool to detect changes to key system files (auditd, AIDE, debsums, tripwire)

Expected Outcomes:

- A detailed technical report (before/after hardening, justification, evidence)



3 . Linux Hardening / Debian

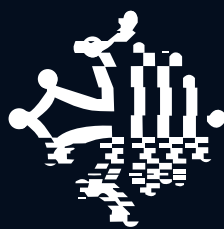
Hardening a Debian Server: Logical Volume Management, Access Control, and Audit Policies

Commands to include in the final report

- lsblk -f
- lsblk
- df -hT
- findmnt
- cat /etc/fstab
- ls /dev/mapper/
- cryptsetup status <volume>
- blkid
- vgs / lvs / pvs
- lsblk -f | grep efi
- efibootmgr -v
- systemctl list-unit-files --type=service | grep enabled
- ss -tuln
- grep '^AllowUsers' /etc/ssh/sshd_config
- getent group admin
- cat /etc/pam.d/common-password
- chage -l <your_user>
- ausearch -f /etc/passwd
- aureport -f
- grep hardening_index /var/log/lynis-report.dat
- ls -l /var/log/lynis*
- auditctl -l
- ausearch -f /etc/passwd
- aide --check
- cat /etc/aide/aide.conf | grep -v ^# | grep -v ^\$
- debsums -s
- lastlog
- journalctl -u ssh
- ls -l /var/lib/aide/aide.db.*
- tripwire --check

Part 2 : OS Hardening

4 . Docker Hardening



4 . Docker Hardening

Docker containers provide isolation but also come with potential security risks. Hardening Docker deployments is crucial for minimizing vulnerabilities and securing the infrastructure.

- **Use Official and Trusted Images**

Always use official Docker images or images from trusted sources to reduce the risk of installing compromised or malicious software.

- **Implement the Principle of Least Privilege**

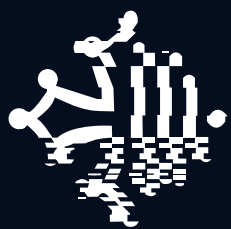
Avoid running containers as the root user. Use Docker's User Namespaces feature to reduce privileges within containers.

- <https://docs.docker.com/engine/security/userns-remap/>

- **Use Docker Bench for Security**

Regularly run Docker Bench for Security to check compliance with Docker security best practices.

- <https://github.com/docker/docker-bench-security>



4 . Docker Hardening

- **Apply Mandatory Access Controls (MAC)**

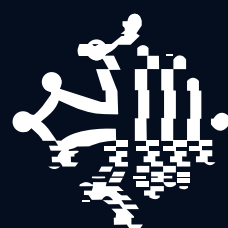
Enforce security profiles with AppArmor or SELinux to limit what a container can do on the host system.

- [Docker AppArmor](#)
- [Docker SELinux](#)

- **Restrict Network Traffic with Firewalls**

Use firewalls like iptables or nftables to limit network traffic to and from containers. Configure Docker's networking to minimize exposure.

- [Docker Networking Best Practices](#)
- [Securing Docker Networks](#)



4 . Docker Hardening

- **Limit Container Capabilities**

Use the `--cap-drop` flag to remove unnecessary Linux capabilities from containers, reducing their potential attack surface.

- [Docker Capabilities](#)

- **Use Read-Only File Systems**

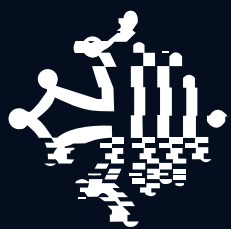
Run containers with a read-only file system to prevent modifications within the container's filesystem.

- [Docker Run Reference - Read-Only Filesystem](#)

- **Scan Images for Vulnerabilities**

Regularly scan Docker images for vulnerabilities using tools like Clair.

- [Clair](#)



4 . Docker Hardening

- **Enable Docker Content Trust (DCT)**

Enforce signature verification of images with Docker Content Trust to ensure the integrity of the images.

- [Docker Content Trust](#)

- **Regularly Update Docker and Host OS**

Keep Docker and the host operating system up to date with the latest security patches.

- **Secure Docker Daemon**

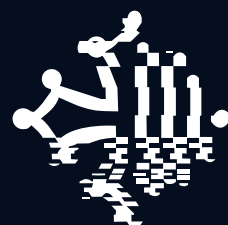
Protect access to the Docker daemon socket (`/var/run/docker.sock`) to prevent unauthorized access to the Docker API.

- [Docker Security Best Practices](#)

- **Use Secrets Management (Docker Swarm)**

Use Docker Secrets to securely manage sensitive information like passwords and API keys.

- [Docker Secrets](#)



4 . Docker Hardening

- **Limit Docker Resource Usage**

Set resource limits on your Docker containers to prevent them from consuming too many resources.

- **Ensure PIDs cgroup Limit is Used**

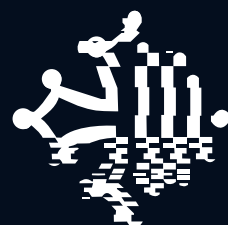
Set PIDs limits on your Docker containers.

- **Use Base Images**

Use minimal when possible. Keeping the images small reduces the attack surface.

References and Tools :

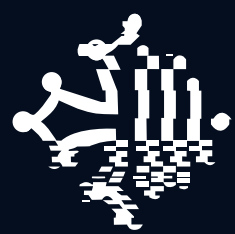
- Docker Documentation: [Docker Documentation](#)
- CIS Docker Benchmark: [CIS Docker Benchmark](#)



4 . Docker Hardening

Lab Docker :

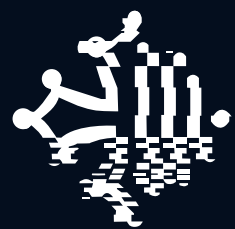
- Deploy a simple web application consisting of three Docker containers : Web proxy + Application server + Database server.
 - The lab should be deployed on the same Linux VM hardened in the previous lab.
 - **Web Proxy Container (Caddy) :**
 - Serves as a reverse proxy to the application server.
 - Expose port 8080 for HTTP traffic.
 - **Application Server Container (Flask) :**
 - Install Flask and create a simple application that connects to the database and display it by any way you want.
 - Expose port 5000 for the Flask app.
 - **Database Server Container (Redis) :**
 - Ensure the database is accessible only by the application server.



4 . Docker Hardening

Lab Docker :

- Requirements :
 - Run Containers with Least Privilege
 - Limit Container Capabilities
 - No new privileges
 - Resource limits
 - Enforce Read-Only Filesystems
 - Network isolation
 - Restrict Network Traffic
 - Run Docker Bench for Security



OXYHACK

4 . Docker Hardening

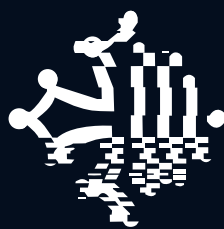
Lab Docker :

[Docker Lab Default HowTo](#)

[Docker Lab Hardened HowTo](#)

Part 3 : SIEM

1. Definitions and General Principles



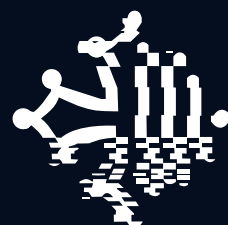
1 . Definitions and General Principles

Definition :

Security Information and Event Management (SIEM) is a set of tools and services that offer a complete view of an organization's IS. SIEM technology enables organizations to detect, analyze, and respond to security threats in real-time.

Core Functions:

- Data Aggregation : Collects logs and events from various sources (servers, network devices, applications).
- Correlation : Analyzes and correlates log data to identify patterns that may indicate security incidents.
- Alerting : Generates alerts for suspicious activities based on predefined rules.
- Dashboards and Reporting : Provides visualizations and reports to help security teams monitor the environment.



1 . Definitions and General Principles

Collect

Aggregates security logs and event data from all sources (servers, network devices, applications, cloud environments) into a centralized repository.

Normalize

Parses and standardizes raw data into a consistent format, making it easier to analyze and correlate across different systems.

Correlate

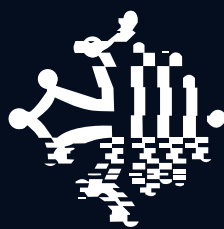
Analyzes normalized data in real-time to identify patterns, anomalies, and potential security incidents that indicate suspicious activity or attacks.

Report

Creates detailed reports for compliance, auditing, and forensic analysis, offering insights into security trends, incident summaries, and overall system health.

Alert

Generates immediate notifications and alerts to security teams when predefined rules or detected anomalies trigger a security event, enabling rapid response.



1 . Definitions and General Principles

How Does SIEM Work ?

- **Data Collection :**

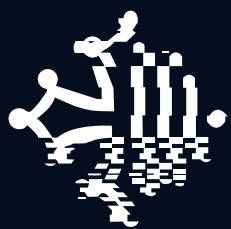
- Sources : Logs from firewalls, routers, endpoints, databases, cloud services...
- Method : Agents or agentless techniques collect and forward logs to the SIEM system.

- **Data Normalization and Correlation :**

- Normalization : Converts logs from various formats into a common structure.
- Correlation : Analyzes logs across different sources to identify patterns or anomalies.

- **Threat Detection and Response :**

- Detection: Uses predefined rules, machine learning, and behavioral analysis to detect threats.
- Response: Triggers alerts and automated actions like escalating incidents.

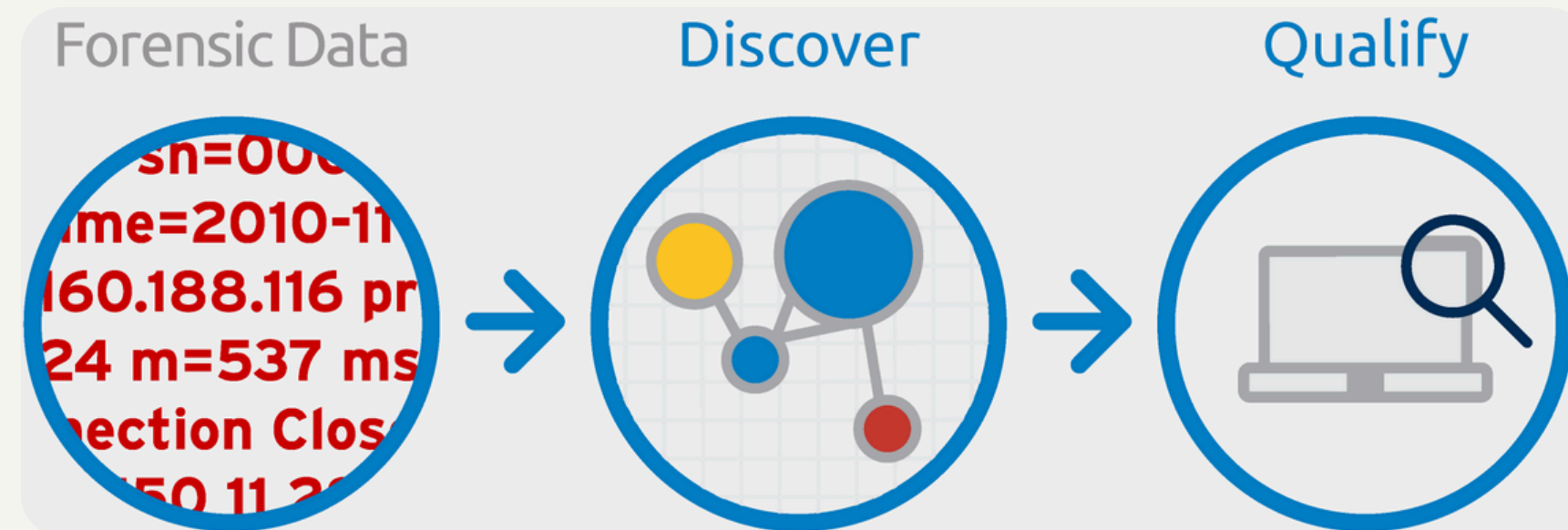


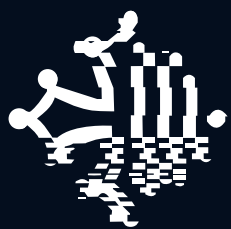
OXYHACK

1 . Definitions and General Principles

How Does SIEM Work ?

- **Reporting :**
 - Reports: Generates reports and security summaries.
 - Dashboards: Provides real-time views of the security posture.





1 . Definitions and General Principles

Understanding XDR, EDR, and SIEM

- **EDR**

- Endpoint Detection and Response, a solution focused on detecting, investigating, and responding to threats on endpoints.
- Method : Continuous Monitoring, Threat Detection Incident Response.

- **SIEM**

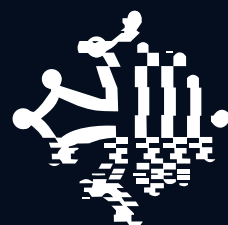
- Provides a comprehensive view of an an IS by aggregating and analyzing log data from various sources.
- Method : Log Management, Correlation, Analysis, Reporting and Compliance.

- **XDR**

- Extended Detection and Response, evolution of EDR that extends threat detection and response capabilities beyond endpoints.
- Method : Holistic View, Automated Correlation, Streamlined Response.

- **SOAR**

- Security Orchestration Automation and Response
- Extends SIEM by providing automated incident response workflows.



1 . Definitions and General Principles

SIEM Use Cases

Brute Force Login Detection

Identifies repeated failed login attempts from an IP address or user, indicating an attacker attempting to guess credentials.

Malware Beaconing

Detects regular, low-volume communication patterns from infected hosts to command-and-control (C2) servers.

Insider Threat Detection

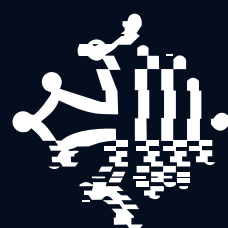
Monitors user behavior for suspicious activities like accessing sensitive data outside normal hours or unusual file modifications by trusted users.

SQL Injection Detection

Recognizes malicious SQL commands embedded in input fields, aimed at manipulating databases or bypassing authentication.

DataExfiltrationDetection

Alerts on unusual outbound data transfers, such as large file uploads or transfers to unsanctioned external destinations.



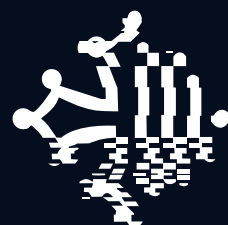
2 . SIEM Lab

Objective

Design, deploy, secure, and monitor a cloud-based cybersecurity infrastructure, including multiple Linux VMs, cybersecurity-oriented services, a centralized SIEM, Dockerized security stacks, and strict Zero Trust policies. All machines must be hardened, interconnected securely, and monitored through the SIEM, with at least one simulated attack triggering an alert.

Target Infrastructure (4 VMs)

VM	Role	Description
vm-siem	Central SIEM	Wazuh, ELK, Graylog....
vm-debian	Access & IAM Services	Guacamole, Teleport, MeshCentral, TacticalRMM,SSH Bastion,.....
vm-fedora	Monitoring & Detection Tools	Zabbix, Centreon, Fail2ban, Honeypot...
vm-docker	Containerized Security Stacks	Portainer + 2 Docker stacks



OXYHACK

2 . SIEM Lab

vm-siem

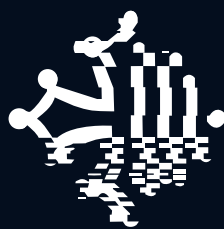
- Deploy a functional SIEM
- Connect all 3 other VMs (system + container logs)
- Create detection rules
- Build dashboards & views
- Detect and log simulated attacks

vm-debian & vm fedora

- One Secure Access & IAM Solution
- One Monitoring or Endpoint Management & Detection
- One OSS tool focused on cybersecurity
- SIEM integration

vm-docker

- Portainer
- Stack 1 – Enterprise Security Solution
- Stack 2 – Enterprise Security Solution
- Container logging and monitoring
- All logs must be forwarded to the SIEM



2 . SIEM Lab

Network Security & Zero Trust

- Private static IPs across VMs
- Cloud security groups/firewalls must restrict access:
 - Only required ports exposed (e.g., VPN, web portals)
 - No default trust between VMs
- Zero Trust policy must be enforced:
 - All communication must be authenticated and encrypted
 - Services should validate user identity at every step
- Secure reverse proxy with TLS and access control lists (ACLs) if needed
- Centralized access is an option but recommended

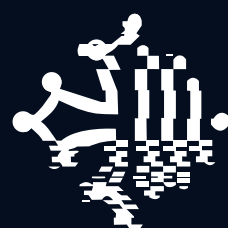
Hardening Requirements (for all VMs)

- SSH access hardened
- Root login disabled
- Active firewall
- Minimal services enabled
- File integrity monitoring
- Logs retained and forwarded to SIEM

Mandatory Attack Simulation

You must simulate a cyberattack and demonstrate that the SIEM:

1. Collects the logs
2. Detects the attack
3. Triggers an alert (mail, telegram, discord...)



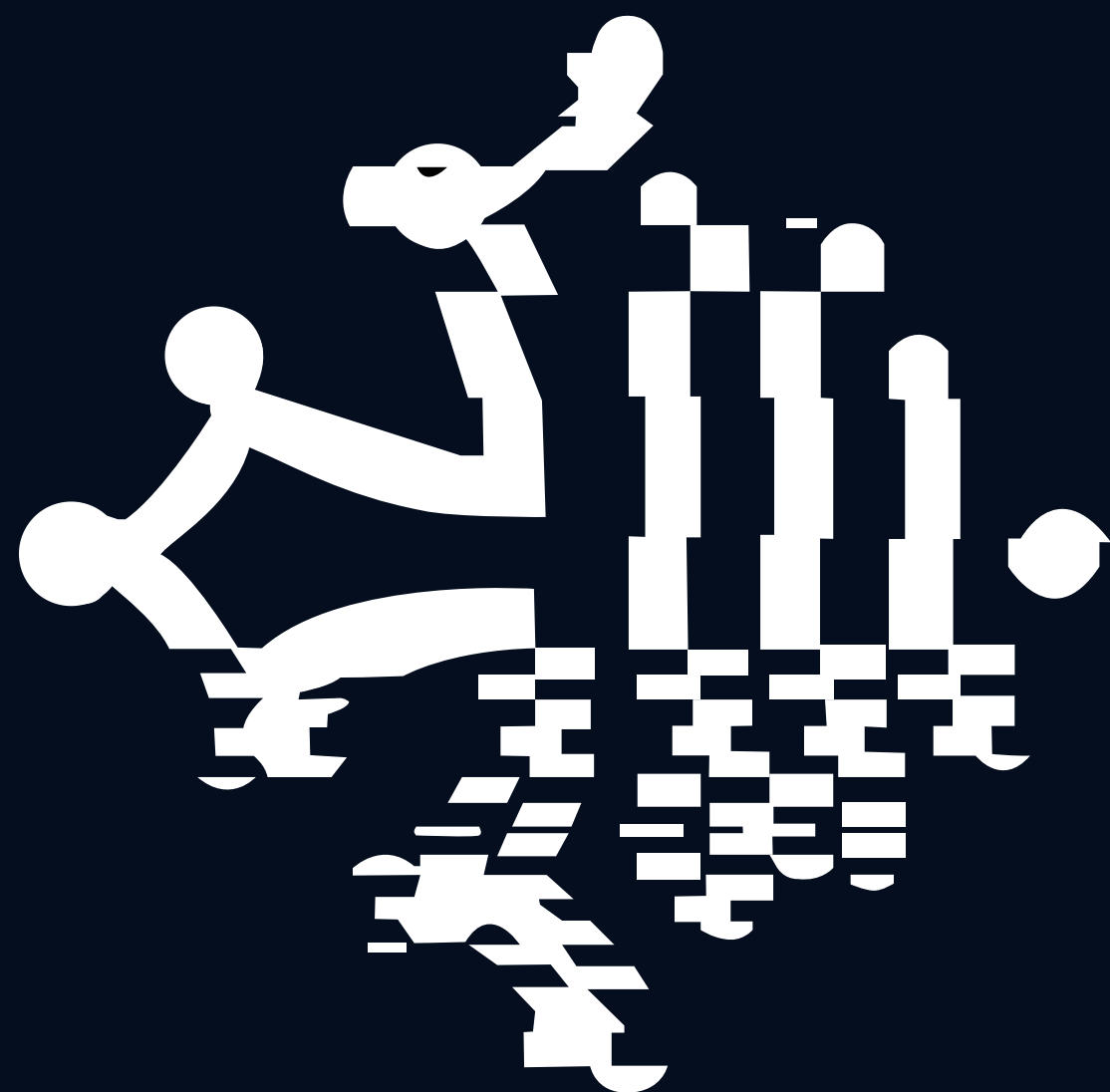
2 . SIEM Lab

Expected Final Report

- **Architecture Diagram** : VMs, IPs, open ports, services, flows...
- **Service Deployment** : Tools used per VM, purpose
- **Hardening** : What was done
- **SIEM Integration** : Tools connected, log types collected
- **Alerts** : Screenshot or output of triggered alerts
- **Attack Simulation** : Scenario, logs, analysis
- **Recommendations** : How to improve detection, reduce attack surface

Grading

- Successful deployment of all services
- SIEM functional and logs integrated
- Zero Trust architecture implemented
- Hardening of all VMs complete
- Detection of at least 1 real attack
- Clear, technical and complete report



OXYHACK

Website

oxyhack.com

Email

contact@oxyhack.com